Laporan Audit Internal ISMS LumiPay

Oct 29, 2026 · @Ali Abdulloh

Audit internal atas dokumen ISMS LumiPay menghasilkan 8 temuan: 2 Mayor, 3 Minor, dan 3 Observasi. Dua temuan Mayor menyangkut scope ISMS (T-02) dan daftar persyaratan hukum yang belum ada (T-07).

LumiPay (PT Lumina Bayar Nusantara) adalah perusahaan fiktif yang dibuat untuk tujuan edukasi dan portofolio. Kemiripan dengan organisasi, produk, atau orang nyata hanyalah kebetulan. Ini bukan pekerjaan untuk klien nyata.

Ruang lingkup dan metode

Audit ini memeriksa dokumen ISMS LumiPay versi 1.0 (per 14 Oktober 2026) dari sisi desain, bukan penerapan di lapangan. Pemeriksaan penerapan dan bukti operasional belum dilakukan karena kontrol sebagian besar masih berstatus Terencana atau Sebagian.

Dokumen yang diperiksa: Profil Perusahaan dan Scope ISMS, Asset Inventory, Kriteria Risiko, Risk Register, rencana Penanganan Risiko, dan Statement of Applicability (SoA).

Kriteria:

- ISO/IEC 27001:2022, klausul 4 sampai 9 yang relevan dengan dokumen yang diperiksa
- ISO/IEC 27002:2022 dan Annex A 27001:2022 untuk kontrol
- Kriteria internal LumiPay: sheet Kriteria Risiko dan aturan di dokumen itu sendiri

Metode: dokumen dibaca maju untuk memahami alur dari konteks sampai SoA, lalu ditelusuri mundur untuk membuktikan. Pemeriksaan difokuskan pada tempat rawan: pengecualian scope, risiko yang diterima, kontrol "Tidak berlaku", status "Belum", dan keputusan risiko sisa. Tiap temuan ditulis dalam lima bagian: Kondisi, Kriteria, Penyebab, Dampak, Rekomendasi, dengan tingkat Mayor, Minor, atau Observasi.

Catatan transparansi: latihan audit ini dipandu, dan dokumen sengaja memuat kelemahan yang harus dicari. Temuan T-01 sampai T-04 ditemukan dan ditulis oleh penulis. Temuan T-05 sampai T-08 disusun dengan bantuan pemandu (Claude, asisten AI) dari pemeriksaan dokumen yang sama, lalu dipelajari ulang oleh penulis. Tujuan latihan adalah belajar cara memeriksa, bukan mengklaim menemukan kelemahan pada sistem nyata.

Daftar temuan

ID	Dokumen dan lokasi	Judul singkat	Tingkat	Status
T-01	Asset Inventory, A-04	A-04 menggabungkan kunci enkripsi dan secret dalam satu aset	Observasi	Terbuka
T-02	Profil Perusahaan dan Scope ISMS, tabel Scope	Pengecualian kantor penjualan Jakarta dan tim pemasaran/penjualan tidak didukung bukti	Mayor	Terbuka

ID	Dokumen dan lokasi	Judul singkat	Tingkat	Status
T-03	Kriteria Risiko, skala kemungkinan	Level 4 dan 5 tidak terukur dan tumpang tindih	Minor	Terbuka
T-04	Kriteria Risiko, baris Rendah	"Tinjauan berkala" tanpa interval pada level Rendah	Observasi	Terbuka
T-05	SoA, kontrol 7.9	Kontrol 7.9 "Tidak berlaku" bertentangan dengan 6.7, 7.14, 8.1, dan R-17	Minor	Terbuka
T-06	Penanganan, R-17	Penerimaan risiko laptop bersandar pada alasan anggaran dan pemantauan yang tidak terukur	Minor	Terbuka
T-07	SoA, kontrol 5.31; Penanganan, R-08	Daftar persyaratan hukum dan kontrak belum ada dan tanpa target	Mayor	Terbuka
T-08	Penanganan, kolom risiko sisa	Risiko sisa dinyatakan dapat diterima sebelum kontrol berjalan, tanpa jadwal verifikasi	Observasi	Terbuka

Rincian temuan T-01 sampai T-04

T-01: A-04 menggabungkan kunci enkripsi dan secret dalam satu aset (Observasi)

Bagian	Isi
Dokumen dan lokasi	Asset Inventory baris A-04; Risk Register dan lembar Penanganan baris R-05
Kondisi	A-04 "Kunci enkripsi dan secret" dicatat sebagai satu aset (pemilik Head of Security, klasifikasi Sangat Rahasia, lokasi secrets manager cloud). Di Risk Register A-04 hanya punya satu risiko, R-05 (skor 12, Tinggi), dengan skenario "kunci jatuh ke penyerang sehingga data terenkripsi bisa dibuka". Skenario penyalahgunaan secret lain, misalnya kredensial atau API key sistem, tidak dirumuskan sebagai skenario sendiri
Kriteria	ISO 27002:2022 kontrol 5.9 (inventaris aset yang akurat dan konsisten); ISO 27001:2022 klausul 6.1.2 (identifikasi dan analisis risiko). Bukan ketidaksesuaian, sehingga dicatat sebagai Observasi
Penyebab	Tampaknya aset dikelompokkan karena lokasi penyimpanan dan pemiliknya sama, bukan karena skenario risikonya sama
Dampak	Kunci dan secret dinilai dengan satu skor (kemungkinan 3, dampak 4), sehingga perbedaan akibat keduanya tidak terlihat dan skenario penyalahgunaan secret bisa luput dari penilaian terpisah. Dampak terbatas karena penanganan R-05 sudah mencakup secrets manager,

Bagian	Isi
	secret scanning, dan rotasi kunci
Rekomendasi	Head of Security memilih salah satu: (1) pisahkan A-04 menjadi dua aset, atau (2) pertahankan satu aset dan tambahkan skenario risiko terpisah untuk penyalahgunaan secret. Hasil akhirnya: tiap jenis punya penilaian risiko yang jelas

T-02: Pengecualian kantor penjualan Jakarta dan tim pemasaran/penjualan dari scope tidak didukung bukti (Mayor)

Bagian	Isi
Dokumen dan lokasi	Profil Perusahaan dan Scope ISMS: tabel Scope (baris Lokasi dan Organisasi), Profil Perusahaan, Isu internal, Antarmuka dan ketergantungan
Kondisi	Tabel Scope mengecualikan kantor penjualan Jakarta ("hanya aktivitas pemasaran tanpa akses data pengguna") dan tim pemasaran dan penjualan, tanpa bukti pendukung. Sementara itu: (1) Profil menyatakan LumiPay melayani UMKM dan mengolah data merchant; (2) Isu internal Klausul 4.1 mencatat budaya sadar keamanan belum merata, terutama di tim non-teknis; (3) bagian Antarmuka dan ketergantungan tidak menjelaskan hubungan dengan kantor atau tim yang dikecualikan; (4) kantor Jakarta disebut di Profil tetapi tidak di Pernyataan scope
Kriteria	ISO 27001:2022 klausul 4.3 (scope mempertimbangkan isu pada 4.1, persyaratan pada 4.2, serta antarmuka dan ketergantungan). Aturan dokumen sendiri: "Pengecualian harus bisa dibenarkan dan tidak boleh melemahkan kemampuan perusahaan menjamin keamanan informasi"
Penyebab	Tampaknya pengecualian ditetapkan berdasarkan asumsi tanpa kajian aktivitas dan akses data kantor tersebut, dan belum ada langkah penentuan scope yang mewajibkan pengecualian dibuktikan
Dampak	Kantor dan tim yang dikecualikan tidak ikut penilaian risiko, kontrol, pelatihan, dan audit internal ISMS; data merchant yang mungkin mereka tangani tidak dinilai risikonya; scope menjadi menyesatkan bagi merchant, bank mitra, dan pihak sertifikasi
Rekomendasi	(1) Nilai aktivitas, sistem, dan akses data kantor Jakarta serta tim pemasaran/penjualan. (2) Jika ada akses ke data merchant atau pengguna, masukkan ke scope dan perbarui pernyataan scope, aset, dan risiko. (3) Jika tetap dikecualikan, dokumentasikan justifikasi berbasis bukti, kontrol batas, dan antarmukanya
Alasan tingkat	Mayor karena scope adalah fondasi ISMS, sehingga kesalahan

Bagian	Isi
	merambat ke aset, risiko, dan SoA

T-03: Level "Sering" dan "Sangat sering" pada skala kemungkinan tidak terukur dan tumpang tindih (Minor)

Bagian	Isi
Dokumen dan lokasi	Kriteria Risiko, tabel Skala kemungkinan (level 4 "Sering" dan level 5 "Sangat sering")
Kondisi	Level 4 didefinisikan "Beberapa kali dalam setahun" tanpa angka minimal dan maksimal. Level 5 didefinisikan "Hampir setiap bulan atau lebih". Kejadian sekali sebulan (12 kali setahun) dapat masuk kedua level, sehingga satu kejadian bisa diberi nilai 4 oleh satu penilai dan 5 oleh penilai lain
Kriteria	ISO 27001:2022 klausul 6.1.2 b (penilaian risiko berulang harus menghasilkan hasil yang konsisten, valid, dan dapat dibandingkan). Tujuan dokumen sendiri: "supaya penilaian konsisten dari satu risiko ke risiko lain"
Penyebab	Tampaknya definisi frekuensi ditulis dengan kata kualitatif tanpa rentang angka, dan batas antar level tidak diperiksa ulang
Dampak	Skor kemungkinan, skor risiko, dan level risiko bisa berbeda antar penilai. Risiko di sekitar batas penerimaan (skor 9) bisa jatuh di atas atau di bawah batas hanya karena beda tafsir
Rekomendasi	Pemilik kriteria menetapkan rentang angka tanpa tumpang tindih untuk tiap level (contoh: level 4 = 2 sampai 5 kali per tahun, level 5 = lebih dari 5 kali per tahun), lalu meninjau ulang penilaian kemungkinan di Risk Register yang memakai level 4 dan 5

T-04: Baris Rendah menyebut "tinjauan berkala" tanpa interval, berbeda dengan baris Sedang (Observasi)

Bagian	Isi
Dokumen dan lokasi	Kriteria Risiko, tabel Level risiko dan batas penerimaan (baris Rendah); lembar Penanganan, kolom Tindakan penanganan
Kondisi	Baris Rendah (skor 1 sampai 4) bertindakan "Dipantau saat tinjauan berkala" tanpa interval, sedangkan baris Sedang pada tabel yang sama menyebut "ditinjau tiap 6 bulan". Lembar Penanganan memakai "tinjauan berkala 6 bulan" hanya untuk risiko Sedang, dan Risk Register tidak memiliki risiko berlevel Rendah
Kriteria	ISO 27001:2022 klausul 6.1.2 a (kriteria penerimaan risiko) dan klausul 8.2 (penilaian risiko pada interval terencana). Konsistensi

Bagian	Isi
	antar baris dalam tabel yang sama
Penyebab	Tampaknya interval hanya ditentukan untuk level yang sudah ada di register (Sedang) dan tidak dilengkapi untuk level lain saat kriteria disusun
Dampak	Saat ini belum terasa. Begitu ada risiko berlevel Rendah, tidak jelas kapan risiko itu dipantau, sehingga bisa tidak pernah ditinjau dan naik level tanpa terdeteksi
Rekomendasi	Tetapkan interval tinjauan untuk level Rendah (contoh: 12 bulan), definisikan istilah "tinjauan berkala" di dokumen kriteria, dan samakan rujukannya di lembar Penanganan

Rincian temuan T-05 sampai T-08

T-05: Kontrol 7.9 dinyatakan "Tidak berlaku" dan bertentangan dengan 6.7, 7.14, 8.1, dan R-17 (Minor)

Bagian	Isi
Dokumen dan lokasi	SoA kontrol 7.9, 6.7, 7.14, 8.1, 8.12; lembar Penanganan baris R-17
Kondisi	SoA 7.9 (Security of assets off-premises) "Tidak berlaku" dengan alasan "seluruh sistem produksi berada di cloud sehingga tidak ada aset sensitif di luar lokasi". Namun: 6.7 berlaku karena karyawan, terutama engineering, bekerja dengan perangkat portabel di luar kantor; 7.14 menyebut laptop harus dihapus datanya termasuk data KYC; 8.1 mencatat laptop menyimpan data kerja dan enkripsi disk belum dijalankan; R-17 "Data perusahaan bocor dari laptop" diterima pada skor 9. Selain itu 8.12 (DLP) "Tidak berlaku" dengan alasan kebocoran data sudah ditangani lewat 8.3, 8.15, dan 8.16, padahal ketiganya berstatus Terencana, target 10 Januari 2027, bukti belum ada. Kolom Cek konsistensi 7.9 menunjukkan "OK"
Kriteria	ISO 27001:2022 klausul 6.1.3 d (SoA memuat justifikasi pengecualian kontrol); ISO 27002:2022 kontrol 7.9. Aturan nomor 8 di SoA sendiri: kecukupan alasan dinilai oleh auditor
Penyebab	Justifikasi pengecualian hanya mempertimbangkan sistem produksi, bukan perangkat kerja karyawan. Pemeriksaan konsistensi otomatis hanya membandingkan kolom dan keterkaitan ID risiko; R-17 tidak dipetakan ke kontrol karena diterima, sehingga pertentangan isi tidak terdeteksi
Dampak	SoA menyatakan tidak perlu kontrol untuk aset di luar lokasi, padahal laptop berisi data kerja dan mungkin data KYC dipakai di luar kantor tanpa enkripsi disk. Kontrol yang dibutuhkan tidak

Bagian	Isi
	direncanakan, dan justifikasi mudah ditolak saat audit sertifikasi
Rekomendasi	(1) Tinjau 7.9: nyatakan berlaku untuk laptop dan perangkat portabel, selaraskan dengan 6.7, 7.14, dan 8.1, atau perbaiki justifikasinya dengan bukti. (2) Tinjau 8.12 agar alasannya tidak bersandar pada kontrol yang belum berjalan. (3) Tambahkan aturan cek konsistensi antara kontrol "Tidak berlaku" dan risiko yang diterima

T-06: Penerimaan risiko R-17 bersandar pada alasan anggaran dan pemantauan yang tidak terukur (Minor)

Bagian	Isi
Dokumen dan lokasi	Lembar Penanganan baris R-17; SoA kontrol 8.1; Kriteria Risiko (batas penerimaan)
Kondisi	R-17 "Data perusahaan bocor dari laptop" memiliki skor 9 (kemungkinan 3, dampak 3), tepat di batas penerimaan. Opsi: Terima. Tindakan: "Dipantau pada tinjauan berkala 6 bulan". Alasan: "enkripsi disk ditunda karena keterbatasan anggaran". Tinjauan berikutnya 12 April 2027. Tidak ada indikator yang dipantau, dan SoA 8.1 tidak memuat target penerapan enkripsi disk
Kriteria	ISO 27001:2022 klausul 6.1.3 f (persetujuan pemilik risiko atas risiko sisa) dan 6.1.2 a (kriteria penerimaan risiko). Catatan di lembar Penanganan: risiko yang diterima wajib punya alasan tertulis dan persetujuan pemilik risiko
Penyebab	Keputusan didorong keterbatasan anggaran, bukan penilaian risiko. Skor berada tepat di batas sehingga lolos kriteria, dan belum ada ketentuan tentang apa yang harus menyertai penerimaan risiko (indikator, batas waktu, kontrol pengganti)
Dampak	Risiko kebocoran data dari laptop hilang atau dicuri tetap terbuka tanpa kontrol pengganti atau tanggal akhir. Jika kemungkinan dinilai satu tingkat lebih tinggi, skor menjadi 12 (Tinggi, di atas batas) dan risiko harus ditangani
Rekomendasi	(1) Nilai ulang R-17 berdasarkan jenis data di laptop, jumlah laptop, dan kemungkinan hilang atau dicuri. (2) Jika tetap diterima, tambahkan kontrol pengganti (misalnya larangan menyimpan data KYC di laptop, kunci layar otomatis, remote wipe) dan tanggal akhir penerimaan. (3) Tetapkan target di SoA 8.1. (4) Tentukan indikator yang dipantau saat tinjauan

T-07: Daftar persyaratan hukum dan kontrak belum ada dan tanpa target (Mayor)

Bagian	Isi
Dokumen dan lokasi	SoA kontrol 5.31; lembar Penanganan baris R-08
Kondisi	SoA 5.31 berlaku dengan dasar "Hukum dan kontrak"; justifikasinya menyebut UU PDP, ketentuan Bank Indonesia, dan perjanjian dengan bank mitra. Status "Belum", target "-", bukti "Belum ada" (daftar persyaratan hukum dan laporan kepatuhan). Dua belas kontrol di SoA memakai dasar "Hukum dan kontrak", termasuk 5.31 (misalnya 5.5, 5.12, 5.24, 5.33, 8.10, 8.11). R-08 "kewajiban hukum terlewat" diterima pada skor 6 dengan tindakan "Dipantau pada tinjauan berkala 6 bulan". Kolom Cek konsistensi 5.31 menunjukkan "OK"
Kriteria	ISO 27001:2022 klausul 4.2 (persyaratan pihak berkepentingan, termasuk hukum dan regulasi, harus ditentukan) dan 6.1.3 d; ISO 27002:2022 kontrol 5.31
Penyebab	Tampaknya daftar persyaratan hukum diperlakukan sebagai pekerjaan lanjutan, dan SoA tidak mewajibkan target untuk kontrol berstatus "Belum". Aturan cek konsistensi hanya menandai status kosong, bukan status "Belum" tanpa target
Dampak	LumiPay belum punya acuan pasti atas kewajiban dari UU PDP, ketentuan Bank Indonesia, dan kontrak bank mitra, sehingga kontrol yang dipilih atas dasar hukum tidak bisa diverifikasi. R-08 dinilai rendah padahal fondasi pemenuhan hukumnya belum ada. Kewajiban yang terlewat dapat berujung sanksi dan pemutusan kerja sama dengan bank mitra
Rekomendasi	(1) Compliance Officer menyusun daftar persyaratan hukum dan kontrak (peraturan, pasal relevan, pemilik, kontrol terkait, bukti) dengan tanggal target. (2) Nilai ulang R-08 setelah daftar selesai. (3) Tambahkan aturan cek: kontrol berstatus "Belum" wajib punya target
Alasan tingkat	Mayor karena persyaratan 4.2 untuk kewajiban hukum belum dipenuhi sama sekali, dan banyak kontrol bergantung padanya

T-08: Risiko sisa dinyatakan dapat diterima sebelum kontrol berjalan, tanpa jadwal verifikasi (Observasi)

Bagian	Isi
Dokumen dan lokasi	Lembar Penanganan (kolom Kemungkinan sisa sampai Penyetuju risiko sisa, dan kolom Target selesai atau tinjau); SoA
Kondisi	Empat belas risiko yang dimitigasi (termasuk dua dengan transfer) memiliki skor sisa 5 sampai 8 dan status "Dapat diterima", disetujui Manajemen atau Pemilik risiko. Kontrol yang menurunkan skor itu

Bagian	Isi
	di SoA berstatus Terencana dengan target 10 Januari 2027 dan bukti belum ada (misalnya 8.3, 8.5, 8.15, 8.16). Catatan lembar Penanganan menyatakan nilai risiko sisa adalah perkiraan yang "perlu diverifikasi", tetapi tidak ada kolom atau tanggal untuk verifikasi itu. Kolom "Target selesai atau tinjau" berisi 10 Januari 2027 (penyelesaian) untuk risiko yang dimitigasi dan 12 April 2027 (tinjauan) untuk risiko yang diterima, sehingga satu kolom memuat dua makna
Kriteria	ISO 27001:2022 klausul 6.1.3 e dan f (rencana penanganan dan penerimaan risiko sisa), 8.3 (penerapan rencana dan catatan hasilnya), dan 9.1 (pemantauan dan pengukuran)
Penyebab	Lembar Penanganan menghitung risiko sisa di muka sebagai rencana, tetapi tidak dirancang untuk mengaitkan penerimaan dengan bukti bahwa kontrol sudah berjalan. Satu kolom dipakai untuk dua tujuan
Dampak	Persetujuan atas risiko sisa diberikan dengan asumsi kontrol efektif. Jika kontrol terlambat atau tidak efektif, tidak ada titik tinjau yang memicu penilaian ulang, sehingga risiko tetap tercatat "diterima" padahal nilainya bisa lebih tinggi
Rekomendasi	(1) Pisahkan kolom "Target selesai penerapan" dan "Tinjauan risiko sisa berikutnya" (misalnya tiga bulan setelah kontrol berjalan). (2) Beri status "Dapat diterima bersyarat" sampai verifikasi selesai. (3) Catat hasil verifikasi di Risk Register

Kesimpulan dan tindak lanjut

Dokumen ISMS LumiPay lengkap secara struktur: 22 risiko dinilai, 93 kontrol Annex A ditinjau, dan rencana penanganan tersedia. Kelemahannya ada pada dasar keputusan, yaitu scope yang tidak dibuktikan, persyaratan hukum yang belum dikumpulkan, dan beberapa justifikasi yang bertentangan dengan dokumen lain. Audit ini hanya menilai desain dokumen; penerapan kontrol belum bisa diperiksa karena sebagian besar masih berstatus Terencana atau Sebagian.

Urutan perbaikan yang disarankan:

Prioritas	Temuan	Tindakan utama	Penanggung jawab usulan
1	T-07 (Mayor)	Susun daftar persyaratan hukum dan kontrak dengan tanggal target; nilai ulang R-08	Compliance Officer
1	T-02 (Mayor)	Nilai aktivitas dan akses data kantor Jakarta dan tim pemasaran/penjualan; masukkan ke scope atau dokumentasikan pengecualian berbasis bukti	Manajemen, pemilik scope ISMS

Prioritas	Temuan	Tindakan utama	Penanggung jawab usulan
2	T-05 (Minor)	Tinjau SoA 7.9 dan 8.12 dan selaraskan dengan 6.7, 7.14, 8.1	Pemilik SoA
2	T-06 (Minor)	Nilai ulang R-17; tambahkan kontrol pengganti dan tanggal akhir penerimaan	Head of IT Support
3	T-03 (Minor)	Tetapkan rentang angka tanpa tumpang tindih pada skala kemungkinan level 4 dan 5	Pemilik kriteria risiko
3	T-08 (Observasi)	Pisahkan kolom penyelesaian dan tinjauan risiko sisa; status "Dapat diterima bersyarat"	Compliance Officer
4	T-01 dan T-04 (Observasi)	Pisahkan aset A-04 atau tambahkan skenario risiko; tetapkan interval tinjauan level Rendah	Head of Security; pemilik kriteria risiko

Langkah berikutnya adalah menyusun rencana tindakan korektif (CAP) untuk tiap temuan, menetapkan tanggal target dan bukti penutupan, lalu memverifikasi penutupan temuan dalam audit tindak lanjut.